مستندات فنی درمان پلاس — معماری و تست‌ها

اردشیر عظیمی نیا@ · Oct 26, 2026

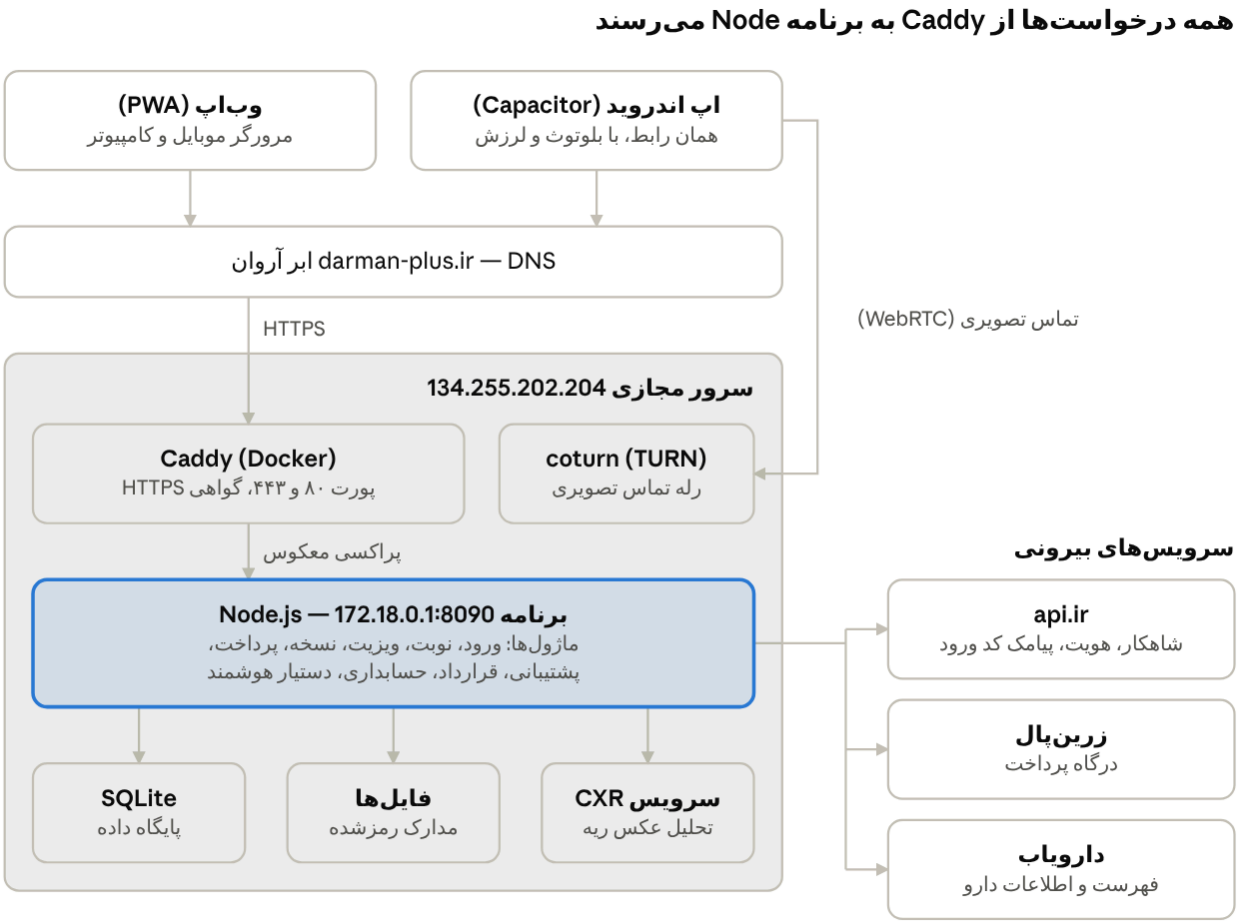
۱. معرفی و دامنه

درمان پلاس یک کلینیک آنلاین است: بیمار نوبت می‌گیرد، پرداخت می‌کند و با پزشک ویزیت تصویری، صوتی یا متنی دارد؛ دستیار هوشمند علائم را بررسی و تخصص مناسب را پیشنهاد می‌کند. سامانه در نشانی روی سرور مجازی شرکت (۱۳۴.۲۵۵.۲۰۲.۲۰۴) در حال اجراست و نسخه اندروید آن ۰٫۴۱ darman-plus.ir است.

مورد	مقدار
زبان و محیط اجرا	جاوااسکریپت، Node.js نسخه ۲۲ (بدون هیچ وابستگی خارجی)
پایگاه داده	SQLite داخلی Node (node:sqlite)
کلاینت‌ها	وب‌اپ (PWA) و اپ اندروید (Capacitor) با یک کد مشترک
ماژول‌های سرور	۱۸ نقطه API، ۱۵۲ ماژول
جدول‌های پایگاه داده	۳۵ جدول
حجم کد	حدود ۱۰٬۶۰۰ خط (سرور و کلاینت)
تست خودکار	۹۳ ۹۳٫۴٪ تست در ۲۰ مجموعه، همه قبول؛ پوشش خط کد
کاربران	بیمار، پزشک، اپراتور و کارشناس پشتیبانی، مدیر (با نقش‌های سفارشی)

۲. معماری کلی

کاربر از وب‌اپ (PWA) یا اپ اندروید وارد می‌شود. درخواست از DNS ابر آروان به Caddy می‌رسد که روی 172.18.0.1:8090 می‌فرستد. برنامه یک Node تنها مالک پورت‌های ۸۰ و ۴۴۳ است و آن را به برنامه فرایند واحد و بدون وابستگی بیرونی است: همه ماژول‌ها در آن اجرا می‌شوند، داده در SQLite و مدارک به‌صورت رمزشده روی دیسک نگه داشته می‌شوند. صدا و تصویر تماس مستقیم بین کلاینت‌ها یا از طریق coturn جابه‌جا می‌شود و از برنامه نمی‌گذرد.



معماری استقرار · کلاینت‌ها، سرور و سرویس‌های بیرونی

۳. ماژول‌های سرور

سرور یک برنامه واحد (src/app.js) خودش را API است که ۱۸ ماژول را ثبت می‌کند؛ هر ماژول مسیرهای زیر (domain) «دارد و از طریق «دامنه /v1 مشترک با بقیه کار می‌کند. همه مسیرها هستند.

ماژول (فایل)	مسئولیت	تعداد API
نوبت‌دهی (appointment.js)	زمان‌های پزشک، رزرو، لغو و بازپرداخت، صف زنده، یادآوری، جابه‌جایی، فایل تقویم	۱۷
پشتیبانی (support.js)	دستیار پشتیبانی، ارجاع، میز کارشناسان (برداشتن، واگذاری، یادداشت)، امتیاز رضایت، گزارش، هشدار تأخیر	۱۶
بیمار و پزشکان (patient.js)	پروفایل بیمار، رضایت‌نامه‌ها، فهرست و معرفی پزشکان، ساخت کادر توسط مدیر	۱۳
دسترسی‌ها (access.js)	نقش‌ها و مجوزها، مدیریت کاربران، غیرفعال‌سازی، تبدیل بیمار به کادر، سابقه ورود و فعالیت	۱۲

ماژول (فایل)	مسئولیت	تعداد API
ویزیت (consultation.js)	اتاق ویزیت، سیگنالینگ تماس تصویری، گفتگوی متنی، نسخه، پایان ویزیت	۱۲
دستیار هوشمند (ai/)	گفتگو، تریاژ قاعده‌محور، اورژانس، دانش‌نامه، ارجاع به اپراتور، آمار و لاگ ممیزی	۱۲
پرداخت (payments.js)	تعرفه‌ها، کمیسیون، درگاه زرین‌پال، نگهداری موقت نوبت، تنظیمات سیستم	۱۰
ورود و هویت (auth.js)	کد یکبارمصرف، استعلام شاهکار، تأیید دومرحله‌ای، شرایط ثبت‌نام، اسناد قانونی عمومی	۹
نسخه و دارو (rx/)	ICD-10، نسخه الکترونیک، هشدار تداخل و حساسیت، فهرست رسمی دارو، الگوهای نسخه	۱۴
پزشکان (doctors.js)	ثبت‌نام و مدارک پزشک، بررسی و تأیید یا رد توسط مدیر	۷
مدارک پزشکی (records.js)	نظر پزشک ،(OCR) مدارک بیمار، خواندن آزمایش از عکس	۷
حسابداری (accounting.js)	سهم پزشک و پلتفرم، تسویه، خروجی اکسل	۶
خلاصه ویزیت (summaries.js)	پیش‌نویس خلاصه، پیش‌نویس ارزیابی، نهایی‌سازی توسط پزشک	۶
قرارداد (contracts.js)	قرارداد همکاری، امضای پزشک و پلتفرم	۴
عکس قفسه سینه (cxr.js)	ارسال به سرویس تحلیل تصویر، نتایج فقط برای پزشک معالج	۴
فایل‌ها (files.js)	بارگذاری رمزنگاری‌شده، لینک امضاشده برای مشاهده	۲

شامل پایگاه داده و مهاجرت، رمزنگاری، پیامک، اعلان، متن قرارداد و اسناد (src/lib) کتابخانه‌های مشترک قانونی، تنظیمات ویزیت، فیلتر محتوای نامناسب و فایل تقویم هستند.

۴. مدل داده

روی سرور شرکت نگهداری می‌شود (۳۵ جدول)؛ هر جدول ستون SQLite همه داده‌ها در یک فایل دارد تا چند کلینیک در یک سامانه جدا بمانند. ستون‌های تازه با مهاجرت افزایشی هنگام tenant_id راه‌اندازی اضافه می‌شوند و داده قبلی حفظ می‌شود.

حوزه	جدول‌ها	نگهداری چه چیزی
کاربران و ورود	users, otp_codes, login_events, staff_roles	حساب‌ها (کد ملی رمزنگاری‌شده)، کدهای یکبارمصرف (فقط هش)، سابقه ورود، نقش‌های کادر و مجوزها

حوزه	جدول‌ها	نگهداری چه چیزی
بیمار	patients, consents, medical_records, files	پروفایل و حساسیت‌ها، رضایت‌نامه‌ها با نسخه، مدارک پزشکی، فایل‌های رمزنگاری‌شده
پزشک	doctors, slots, doctor_contracts, doctor_payouts, rx_templates	پروفایل و وضعیت تأیید، زمان‌های منتشرشده، قرارداد امضاشده، تسویه‌ها، الگوهای نسخه
نوبت و ویزیت	appointments, consultations, visit_summaries, prescriptions	نوبت (وضعیت، لغو، سیاست بازپرداخت)، اتاق ویزیت، خلاصه و نسخه امضاشده
مالی	payments, settings	پرداخت‌ها با سهم پزشک و پلتفرم، تعرفه و تنظیمات سیستم
دستیار هوشمند	chat_sessions, messages, triage_results, escalations, cxr_analyses	گفتگوها، نتیجه تریاژ، ارجاع‌ها به اپراتور، تحلیل عکس قفسه سینه
پشتیبانی	support_tickets, support_messages, support_notes, moderation_events	گفتگوهای پشتیبانی، امتیاز رضایت، یادداشت‌های داخلی، پیام‌های ردشده
دارو	drug_catalogs, erx_items, erx_deleted, drug_api_cache	فهرست رسمی دارو (کد eRx)، کدهای حذف‌شده، حافظه موقت دارویاب
سیستم	notifications, outbox_events, audit_logs	اعلان‌ها، رویدادهای داخلی، لاگ ممیزی غیرقابل‌تغییر

۵. جریان‌های اصلی

پنج جریان زیر بیشتر رفتار سامانه را تعیین می‌کنند؛ هر کدام در بخش تست‌ها دستکم یک تست خودکار دارد.

ثبت‌نام و ورود

1. کاربر نوع کاربری (بیمار یا پزشک و کادر) و شماره موبایل را وارد می‌کند.
2. شماره تازه: صفحه تأیید شرایط (پنج بند)، سپس کد ملی و استعلام شاهکار (تطابق شماره با کد ملی). در حساب ثبت می‌شود IP نسخه شرایط پذیرفته‌شده، زمان و.
3. پیامک می‌شود (هر دقیقه یک بار، حداکثر ۳ بار در ۱۰ دقیقه) api.ir کد یکبارمصرف از طریق.
4. پزشک، اپراتور و مدیر یک کد دوم هم می‌گیرند (تأیید دومرحله‌ای). خروجی: توکن ۸ ساعته؛ با غیرفعال‌سازی حساب یا تغییر نقش بی‌درنگ باطل می‌شود.

نوبت، پرداخت و لغو

1. پزشک بازه کاری را منتشر می‌کند؛ تعداد نوبت از مدت ویزیت (در تنظیمات سیستم) حساب می‌شود.

2. بیمار زمان را انتخاب می‌کند؛ نوبت ۱۵ دقیقه برای پرداخت نگه داشته می‌شود. هر رزرو کلید یکتا (Idempotency-Key) دارد تا تکرار درخواست نوبت دوم نسازد.
3. پرداخت در درگاه زرین‌پال؛ با تأیید بانک، نوبت «تأییدشده» و سهم پزشک و پلتفرم ثبت می‌شود.
4. لغو توسط بیمار تا ۲۴ ساعت قبل = بازپرداخت؛ دیرتر = بدون بازپرداخت (درآمد پزشک). لغو توسط پزشک = اعتبار بیمار: زمان جدید بدون پرداخت یا بازگشت کامل وجه.

ویزیت و صف

1. یک ساعت قبل یادآوری؛ اتاق ویزیت از زمان تعیین‌شده (پیش‌فرض ۱۰ دقیقه قبل) تا ۳۰ دقیقه بعد از پایان نوبت باز است؛ زمان با ساعت سرور سنجیده می‌شود.
2. صف زنده: تعداد نفرات پیش از بیمار، زمان تقریبی شروع، اعلان «نوبت شما بعدی است» و اعلان تأخیر بیش از ۱۵ دقیقه.
3. تماس تصویری دونفره (WebRTC) روی سرور شرکت؛ در اینترنت ضعیف به صوتی و TURN با رله متنی.
4. پایان ویزیت: پیش‌نویس خلاصه و ارزیابی، کامل شدن تشخیص توسط پزشک، نسخه امضاشده، سپس نمایش به بیمار.

پشتیبانی

1. دستیار پشتیبانی از دانش‌نامه ۲۱ موضوعی پاسخ می‌دهد؛ پیام نامناسب رد می‌شود.
2. درخواست کارشناس، شکایت یا دو پاسخ ناموفق پشت سر هم = ارجاع و اعلان به کارشناسان.
3. کارشناس گفتگو را برمی‌دارد، پاسخ می‌دهد یا واگذار می‌کند؛ بی‌پاسخی بیش از زمان تعیین‌شده به سرپرست هشدار می‌دهد.
4. بستن گفتگو ← پنجره امتیاز ۱ تا ۵ ← گزارش عملکرد هر کارشناس.

پزشک و قرارداد

1. ثبت‌نام و ارسال مدارک (کارت نظام پزشکی، عکس، معرفی).
2. بررسی مدیر: تأیید، یا رد با دلیل و ارسال دوباره.
3. پزشک قرارداد ۱۳ ماده‌ای را تکمیل و با امضای دستی روی صفحه امضا می‌کند؛ نوبت‌دهی فعال می‌شود.
4. نماینده پلتفرم امضا می‌کند؛ نسخه امضاشده با پیوست مالی منجمد و قابل چاپ است.

۶. امنیت، حریم خصوصی و دسترسی‌ها

داده‌ها روی سرور داخل کشور می‌مانند و حساس‌ترین‌ها رمزنگاری می‌شوند؛ هر دسترسی به نقش و مجوز مشخص وابسته است و اقدام‌های حساس در لاگ ممیزی ثبت می‌شوند.

سازوکار	لایه
استعلام شاهکار و ثبت احوال (api.ir)؛ یک حساب بیمار برای هر کد ملی؛ نام رسمی قفل می‌شود	هویت

لایه	سازوکار
ورود	کد یکبارمصرف ۲ دقیقه‌ای و ۵ تلاش؛ تأیید دومرحله‌ای برای پزشک و کادر؛ توکن امضاشده ۸ ساعته که با غیرفعال‌سازی یا تغییر نقش بی‌درنگ باطل می‌شود
رمزنگاری	کد ملی و فایل‌های بارگذاری‌شده رمزنگاری‌شده ذخیره می‌شوند؛ جستجوی کد ملی با هش HMAC؛ ارتباط HTTPS با گواهی Let's Encrypt
دسترسی	چهار نقش پایه + نقش‌های سفارشی کادر با ۱۳ مجوز؛ پرونده بیمار فقط برای پزشک همان نوبت؛ آخرین مدیر کل قابل حذف نیست
فایل و لینک	لینک‌های امضاشده و تاریخ‌دار برای فایل و تقویم؛ نوع فایل از محتوای آن تشخیص داده می‌شود
محدودیت نرخ	برای هر کاربر؛ ۳۰۰ درخواست در دقیقه برای هر IP، ۶۰۰ محدودیت جدا برای کد پیامکی، شاهکار و دستیار
محتوا	فیلتر توهین، واژه رکیک، تبلیغ و متن بی‌معنی؛ پنج پیام ردشده در یک ساعت = توقف یک‌ساعته
دستیار هوشمند	قواعد اورژانس پیش از هر مدل؛ ممانعت از تشخیص و دوز دارو؛ شناسایی تزریق دستور (prompt injection)
مرورگر	سیاست امنیتی محتوا (CSP) بدون منبع بیرونی، فونت محلی، CORS فقط برای اپ اندروید
سرور	برنامه فقط روی شبکه داخلی Docker؛ fail2ban روی SSH گوش می‌دهد (172.18.0.1:8090)
ردیابی	لاگ ممیزی غیرقابل‌تغییر (خواندن پرونده، نسخه، پاسخ و دستگاه IP پشتیبانی، تغییر نقش)؛ سابقه ورود با

رضایت‌نامه‌های اختیاری (دسترسی دستیار به سوابق، ضبط ویزیت، آموزش مدل) نسخه‌دار و قابل لغو هستند و کاربر می‌تواند نسخه کامل داده‌های خود را دریافت کند.

۷. استقرار و عملیات

کد را از گیت‌هاب می‌گیرد، (deploy/install.sh) سامانه با یک دستور نصب یا به‌روز می‌شود؛ نصب‌کننده نگه می‌دارد. اجرای دوباره /etc/kx21.env را می‌سازد و تنظیمات را در kx21 به نام systemd سرویس همان دستور = به‌روزرسانی؛ داده و تنظیمات حفظ می‌شوند.

```
curl -fsSL https://raw.githubusercontent.com/ardeshirazimi2000-
design/kx21/<commit>/deploy/install.sh | sudo DOMAIN=darman-plus.ir
BEHIND_PROXY=1 APP_BIND=172.18.0.1 PUBLIC_IP=134.255.202.204 bash
```

نقش	جزء روی سرور
برنامه Node روی 172.18.0.1:8090 Docker؛ پس از بالا می‌آید و در صورت خطا هر ۵ ثانیه دوباره تلاش می‌کند	سرویس kx21 (systemd)
تماس تصویری (پورت ۳۴۷۸ و بازه ۴۹۱۶۰ تا ۴۹۲۰۰) رله TURN	coturn
برای تحلیل تصویر، فقط (cxr) سرویس پایتون جدا کمکی پزشک	سرویس عکس قفسه سینه
مسدودسازی تلاش‌های ناموفق SSH	fail2ban
روی پورت‌های خودشان (۸۰۰۰، ۸۱۰۰، ...)؛ هیچ‌کدام نباید پورت ۸۰ یا ۴۴۳ بگیرد	سامانه‌های دیگر (kx21-web، kx21-office، backend، وبینار)

متغیرهای اصلی /etc/kx21.env:

کاربرد	متغیر
حالت عملیاتی و شماره مدیر کل	PRODUCTION, ADMIN_PHONE
شاهکار، ثبت احوال و پیامک کد ورود (api.ir)	SAPI_TOKEN, SMS_PROVIDER=apiir
خط پیامک متنی برای یادآوری‌ها (فعلاً خالی)	SMS_SENDER, SMS_API_KEY
درگاه پرداخت (فعلاً خالی)	ZARINPAL_MERCHANT_ID
اجرا پشت Caddy داخل Docker	APP_BIND, BEHIND_PROXY, TRUSTED_PROXIES
نشانی عمومی سایت	PUBLIC_BASE_URL, DOMAIN

برای ImprovMX به MX و رکوردهای (با حالت ابری خاموش A رکورد) دامنه در ابر آروان است از همان فایل‌های وب ساخته می‌شود و Capacitor اشاره می‌کنند. اپ اندروید با info@darman-plus.ir نشانی سرور در آن ثابت است.

۸. تست‌ها

هر ۹۳ تست خودکار در آخرین اجرا قبول شدند (حدود ۲۴ ثانیه)؛ پوشش کد سرور: خط ۹۳٫۴٪، شاخه ۷۸٫۲٪، تابع ۹۰٫۷٪. تست‌ها با ابزار داخلی Node (node:test) نوشته شده‌اند، هر مجموعه یک سرور داخلی صدا می‌زند؛ شاهکار، پیامک HTTP واقعی روی پورت تصادفی با پایگاه داده موقت بالا می‌آورد و از بیرون با درگاه زرین‌پال شبیه‌سازی می‌شوند.

```
npm test
node --test --experimental-test-coverage 'test/**/*.test.js'
```

مجموعه	تعداد	چه چیزی را می‌سنجد
visual-triage	۱۲	تریاژ تصویری: نشانه‌های اورژانسی همیشه برنده‌اند، علائم حیاتی، ارجاع به انسان
api	۱۳	ثبت‌نام و شاهکار، رزرو بی‌تکرار، دستیار، ورود دومرحله‌ای پزشک، لاگ ممیزی، محدودیت نرخ، CORS، TURN
requirements-v2	۱۰	ثبت احوال، پزشک و قرارداد، تعرفه و پرداخت، مدارک بیمار و نظر پزشک
ai-rules	۶	قواعد اورژانس، تریاژ، ممانعت از تشخیص و دوز، تزریق دستور، دانش‌نامه
ble-health	۶	خواندن فشارسنج، پالس‌اکسیمتر، دماسنج و ضربان قلب بلوتوث
support	۵	دستیار پشتیبانی، نقش کارشناس، امتیاز، فیلتر محتوا، چند کارشناس و هشدار تأخیر
appointment-flow	۵	بازه ورود به اتاق، یادآوری، لغو پزشک، صف زنده، مدیریت گروهی زمان‌ها
sms-production	۵	ارسال پیامک، حالت عملیاتی، مدیر کل، جلوگیری از کدهای تکراری
accounting-access	۴	کمیسیون و تسویه، نقش‌های کادر، غیرفعال‌سازی، سابقه ورود
lab-ocr	۴	خواندن برگه آزمایش از عکس
rx-safety	۴	امضای نسخه، الگوها، ICD-10، تداخل و حساسیت دارویی
visit-summary	۴	پیش‌نویس خلاصه و ارزیابی، الزام نوشتن تشخیص توسط پزشک
drug-directory	۳	جستجوی دارویاب و مونوگراف دارو
cancellation-rules	۲	قوانین لغو و بازپرداخت، فایل تقویم
cxr	۲	تحلیل عکس قفسه سینه، فقط برای پزشک معالج
drug-catalog	۲	بارگذاری فهرست رسمی دارو و نسخه با کد eRx
fa-translit	۲	جستجوی نام فارسی دارو
rx-suggest	۲	پیشنهاد نسخه از سابقه خود پزشک

چه چیزی را می‌سنجد	تعداد	مجموعه
دستیار و نبود زمان آزاد در تخصص خواسته‌شده	۱	assistant-specialty
مدت‌های مجاز ویزیت	۱	visit-settings

کم‌پوشش‌ترین فایل‌ها: متن اسناد قانونی (۲۵٪)، اتصال به مدل زبانی بیرونی (۵۹٪)، بخش بیمار و پزشکان (۸۰٪) و پرداخت (۸۳٪).

آزمون در مرورگر: هر صفحه تازه با Playwright (کرومیوم) در اندازه آیفون، اندروید و کامپیوتر و در حالت تیره باز و از آن تصویر گرفته شده است. **آزمون روی گوشی واقعی** (صدا، لرزش، تقویم آیفون، تماس تصویری روی اینترنت همراه) با تیم شماست؛ مواردی که شما گزارش دادید (ستاره‌ها، تقویم آیفون، بزرگ‌شدن صفحه) اصلاح شده‌اند، اما تقویم آیفون هنوز دوباره آزموده نشده است.

۹. محدودیت‌ها و کارهای باز

مورد	وضعیت فعلی	اقدام پیشنهادی
پشتیبان‌گیری	از پایگاه داده و فایل‌های رمزشده هیچ نسخه پشتیبانی گرفته نمی‌شود	پشتیبان روزانه خودکار به فضای جدا از سرور، با آزمون بازگردانی
پیامک یادآوری	فقط کد ورود پیامک می‌شود؛ یادآوری‌ها درون برنامه و از طریق «افزودن به تقویم» است	فعلاً به دلیل هزینه کنار گذاشته شده؛ در صورت نیاز خط خدماتی پیامک
اعلان فوری (Push)	اعلان فقط وقتی برنامه باز است دیده می‌شود	راه‌اندازی سرویس اعلان اندروید/وب
آزمون روی گوشی واقعی	آزمون‌ها روی مرورگر شبیه‌سازی‌شده انجام شده	آزمون تماس تصویری، صدا و تقویم روی آیفون و اندروید واقعی
تست ناپایدار	یک بار یک تست شکست خورد و در ۶ اجرای بعدی قبول شد	ریشه‌یابی پیش از اتکا به آن در استقرار خودکار
پیوست‌های قرارداد پزشک	پیوست مالی ساخته می‌شود؛ پیوست خدمات، فنی و نگهداری سوابق هنوز متن ندارند	تهیه متن توسط مشاور حقوقی
درگاه پرداخت	کد پذیرنده زرین‌پال ثبت نشده؛ پرداخت در حالت آزمایشی است	ثبت کد پذیرنده پس از دریافت نماد
اینماد	در حال دریافت	تکمیل و قرار دادن نشان در پای صفحه
زبان	فقط فارسی	—
مقیاس	یک سرور و پایگاه داده SQLite	برای چند هزار کاربر هم‌زمان کافی است؛ پس از آن انتقال پایگاه داده